

Risk register – RDM as a tool

Document ID	RMF-001
Revision	74773d1
Date	2026-10-03
Status	proposed

Contents

1 Risks 3

Id: RMF-001 · Kind: risk · Status: proposed

1 Risks

- **RISK-TOOL-001**
 - *Category:* safety
 - *Status:* proposed
 - *Hazard:* Tag discovery reads a design-input id from text that is not a tag.
 - *Situation:* A test writes a fixture file naming DI-n, and no real test verifies DI-n.
 - *Harm:* The matrix reports DI-n verified, and a team releases software whose requirement nobody tested.
 - *Severity:* Serious
 - *Probability:* Possible
 - *Controls:* DI-40
 - *Residual:* probability Rare
- **RISK-TOOL-002**
 - *Category:* safety
 - *Status:* proposed
 - *Hazard:* The release gate passes a design input whose test failed or never ran.
 - *Situation:* A test fails, errors or is skipped in CI, and the release gate still reports PASSED.
 - *Harm:* A team releases software with a requirement that is not verified.
 - *Severity:* Serious
 - *Probability:* Possible
 - *Controls:* DI-3, DI-4
 - *Residual:* probability Rare
- **RISK-TOOL-003**
 - *Category:* safety
 - *Status:* proposed
 - *Hazard:* Implementation lands before its design input is approved.
 - *Situation:* An author or agent commits code while the design document that governs it is uncommitted or edited.
 - *Harm:* The record shows a design approved after the code it governs; an audit finds design controls not followed.
 - *Severity:* Minor
 - *Probability:* Possible
 - *Controls:* DI-2, DI-71
 - *Residual:* probability Unlikely
- **RISK-TOOL-004**
 - *Category:* security
 - *Stride:* Tampering
 - *Status:* proposed
 - *Hazard:* An agent changes the controlled record through RDM without review.
 - *Situation:* An agent connected to rdm graph mcp issues a SPARQL Update or looks for a write tool.

- *Harm*: The record diverges from what reviewers approved, and evidence no one reviewed is presented as controlled.
- *Severity*: Serious
- *Probability*: Possible
- *Controls*: DI-42
- *Residual*: probability Rare
- **RISK-TOOL-005**
 - *Category*: safety
 - *Status*: proposed
 - *Hazard*: A tagged test passes without checking everything its design input requires.
 - *Situation*: A test checks two of the three things a design input requires, and the pull-request reviewer does not notice.
 - *Harm*: The design input is reported verified while one thing it requires is unchecked, and the gap ships.
 - *Severity*: Serious
 - *Probability*: Possible
 - *Controls*: DI-34
 - *Residual*: probability Unlikely
 - *Acceptance*: by RDM maintainers, by approving the pull request that records this register; rationale Whether a test proves its input is a reviewer's judgement. The mutation probe makes it checkable on demand; requiring it for every clause is the faithfulness gate Design Review 4 retired for costing more than it caught. Monitored by reviewers probing the tests a change touches.
- **RISK-TOOL-006**
 - *Category*: security
 - *Stride*: Tampering
 - *Status*: proposed
 - *Hazard*: The served graph accepts SPARQL updates from any web origin.
 - *Situation*: A person browses the graph in Graph Explorer while a web page they have open posts an update to the local endpoint.
 - *Harm*: The graph the person reviews is cleared or shows forged verification, and they act on evidence the record does not hold.
 - *Severity*: Serious
 - *Probability*: Unlikely
 - *Controls*: DI-36
 - *Residual*: probability Rare
- **RISK-TOOL-007**
 - *Category*: security
 - *Stride*: Information disclosure
 - *Status*: proposed
 - *Hazard*: A read-only query can make RDM send network requests.
 - *Situation*: A prompt-injected agent, or a web page posting to the served endpoint, sends a query with a SERVICE clause naming an internal or external address.
 - *Harm*: The server probes or reaches services from the user's machine, outside the review the record is under.
 - *Severity*: Serious

- *Probability*: Unlikely
- *Controls*: DI-42, DI-36
- *Residual*: probability Rare

Proposed, not yet approved. An agent wrote these ratings and the acceptance of RISK-TOOL-005; a maintainer approves each by reviewing it and setting `status: approved` (or changing it).

RDM is not a medical device. Teams use it to keep and check the evidence for one, so its risks are the ways it could misreport that evidence. Each control is a design input of RDM's own record, verified by its tagged test; the release gate holds this register to the rules in `design/risk.md` (DI-44).

Evaluated against RDM's risk policy (`policy.md`, RMP-001): severity from the harm, probability from the situation, residual after the controls. RISK-TOOL-005 stays at Medium after its control and is accepted above, with the reason.